THREAT ADVISORY

Citrix NetScaler: Two RCE Zero-Days Under Attack

Citrix has confirmed active exploitation of two critical NetScaler RCE flaws. Patches are available, but organizations should check whether exposed appliances were compromised before the update.

Sources: **Citrix CTX697096** · **CISA Alert** · 27 Sep 2026
CVE-2026-88771 · CVE-2026-88772

Memori CTI

ACTIVE EXPLOITATION / 27 SEPTEMBER 2026

Two flaws, already under attack.

Citrix patched two critical NetScaler RCE vulnerabilities after attacks had been observed against customer deployments.

THE CONFIRMED FACTS

CVE-2026-88771 and CVE-2026-88772 each score 9.5 under CVSS v4.0. Citrix confirms exploitation of both. CISA added them to its KEV catalog and reports active exploitation globally.

How the warning surfaced

25 SEP	Administrators report private shutdown warnings on Reddit.
26 SEP	watchTowr publicly warns of credible NetScaler RCE attacks.
27 SEP	Citrix publishes CTX697096 and fixed builds; CISA issues an alert.

SCOPE

CTX697096 addresses eight vulnerabilities. This brief examines the two RCE zero-days with confirmed exploitation; CVE-2026-88773 is also Critical (9.3).

Early “no patch yet” reports predate the 27 September fixes. The volume of attacks remains unclear, and no attacker has been publicly identified.

CVE-2026-88771 / IMPROPER INPUT VALIDATION

No additional feature is required for exposure.

All supported affected NetScaler ADC and Gateway deployments meet Citrix's configuration precondition, including default installations.

9.5

CVSS v4.0 / Critical
CWE-20: Improper Input Validation

What makes this one broad

NO FEATURE GATE

Citrix lists no additional service or optional setting that must be enabled on an affected deployment. The CVSS v4.0 vector still records attack requirements (AT:P).

NO LOGIN REQUIRED

The vendor describes an unauthenticated route to arbitrary command execution. An exposed, vulnerable appliance therefore needs urgent attention even if its VPN functions are not used.

Scope first: identify every customer-managed ADC and Gateway, record the installed build, then compare it with the fixed release for that branch.

CVE-2026-88772 / MEMORY OVERFLOW

The DTLS condition matters.

The second flaw can cause remote code execution or denial of service when DTLS is enabled on a NetScaler ADC or Gateway.

9.5

CVSS v4.0 / Critical
CWE-119: Improper Restriction of Operations within the Bounds of a Memory Buffer

VPN virtual servers enable DTLS by default

Citrix says a Gateway meets this precondition unless DTLS has been explicitly disabled. Other virtual servers can also be affected when configured with type DTLS.

DTLS ON BY DEFAULT

add vpn vserver vpn1 SSL ...
(no explicit -dtls OFF setting)

EXPLICITLY DISABLED

add vpn vserver vpn1 SSL ... -dtls OFF
This removes the CVE-2026-88772 precondition for that VPN server.

DTLS being off does not address CVE-2026-88771. The two flaws must be assessed separately.

OPERATIONAL ANALYSIS

Where is the exposure?

CVE-2026-88771 has no feature-specific configuration precondition; CVE-2026-88772 depends on DTLS.

Build an appliance list before the patch window

01 / INVENTORY

Find customer-managed NetScaler ADC and Gateway instances, including Secure Private Access hybrid deployments that use NetScaler.

02 / BUILD

Record the branch and full build number. An older build is in scope even when the appliance was patched for an earlier NetScaler CVE.

03 / DTLS

Review VPN virtual servers for an explicit -dtls OFF setting and look for other DTLS virtual servers.

04 / REACHABILITY

Prioritize appliances reachable from untrusted networks, then review restricted and internal deployments as well.

A low exposure profile does not erase previous risk: if an appliance was reachable while vulnerable, review the earlier activity after updating it.

REMEDIATION MATRIX

Match the fix to the branch.

These are Citrix's fixed builds for supported affected branches. Confirm the installed version after deployment.

PRODUCT BRANCH	FIXED BUILD
ADC / Gateway 14.1	**14.1-73.37+**
ADC / Gateway 13.1	**13.1-64.23+**
ADC 14.1-FIPS	**14.1-73.37 FIPS+**
ADC 13.1-FIPS / NDcPP	**13.1-37.279+**

LEGACY BRANCHES

Citrix lists fixes for supported 14.1 and 13.1. Tenable notes that 12.1 and 13.0 are EOL; Citrix has not stated whether they are affected. Absence from this table is not evidence of safety.

BULLETIN SCOPE

The advisory covers six more CVEs. CVE-2026-88773 is Critical (9.3). For CVE-2026-88778, Citrix also directs customers to enable Enhanced ISN Generation where applicable; an upgrade alone does not complete that issue's remediation.

BEFORE THE CHANGE WINDOW

Three upgrade details to check.

Citrix's release includes operational notes that matter when planning and verifying the deployment.

13.1-64.23 REBOOT LOOP

Run "show ns variable". If it returns configured variables, Citrix advises upgrading to 13.1-64.24 to avoid a cyclic reboot issue.

SIGNED SAML ASSERTIONS

The update no longer supports samlRejectUnsignedAssertion OFF. That setting is converted automatically; confirm that the identity provider issues signed SAML assertions.

CONSOLE SCAN RESULT

NetScaler Console may temporarily flag a system running 13.1-64.23 as vulnerable. Citrix says this is an interim Security Advisory scan issue and does not require another appliance upgrade.

These notes concern upgrade behavior and scan interpretation. They do not change the urgency of applying the fixed build and checking for previous compromise.

INCIDENT RESPONSE

What patching cannot tell you.

A fixed build addresses these flaws. It cannot tell you whether an appliance was compromised beforehand.

01 **Before updating**

Preserve relevant logs and a memory dump where feasible. CISA warns an update may remove forensic visibility.

02 **Check for compromise**

Use Citrix's generic IOC assessment when its Console prerequisites are met, or seek the indicators from Citrix Support.

03 **Install and verify**

Apply the fixed build for the branch, confirm the running version, and continue investigating any suspicious findings.

HUNTING REFERENCE

Indicators & hunting clues

Citrix offers generic IoCs through NetScaler Console. The scan is an initial check alongside preserved appliance and external logs.

01

VENDOR IOC SCAN

Use NetScaler Console Security Advisory. Customers without access can request the generic indicators or scanning help from Citrix Support.

SCAN PREREQUISITES

Console 14.1-73.36 or later; Cloud Connect for on-premises Console; telemetry enabled. The option appears when Citrix releases detection logic and the user accepts its terms.

02

LOG CORRELATION

Review pre-patch appliance activity alongside authentication and network logs. Investigate unexpected access around exposed services.

03

FILE CHANGES

Use NetScaler Console File Integrity Monitoring and preserved evidence to assess unauthorized changes. Escalate suspicious findings.

A clean IOC result cannot rule out compromise: Citrix says its indicators do not cover every attacker technique.

Stay vigilant. **Follow Memori CTI for more threat intel.**